

ThreatMesh AI: A Trust-Aware Supply Chain Cyber Threat Intelligence Platform via an Adaptive Dependency Trust Graph and Multi-Agent Explainable Reasoning

Aditi Kadam¹, Arya Nate², Vansh Pandey³, Anshul Nagpure⁴

^{1,2,3,4}*Vishwakarma Institute of Technology*

Team ThreatMesh — Cybersecurity / Agentic AI Track

¹aditi.kadam@vit.edu, ²arya.nate@vit.edu

³vansh.pandey@vit.edu, ⁴anshul.nagpure@vit.edu

Abstract— Modern applications are assembled from hundreds to thousands of transitive open-source dependencies, and attackers increasingly exploit this surface through dependency confusion, typosquatting, and compromised maintainer accounts, as evidenced by Log4Shell (2021) and the XZ Utils backdoor (2024). Industry data confirms the trend is accelerating: third-party involvement now accounts for 48% of breaches, up 60% year-over-year, and vulnerability exploitation has overtaken stolen credentials as the leading initial-access vector. Existing software composition analysis (SCA) and threat-intelligence tools treat dependency trust as a static, point-in-time judgment and rarely connect it to graph-based exploit reachability or explainable remediation. We present ThreatMesh AI, an SBOM-anchored platform built around the Adaptive Dependency Trust Graph (ADTG): a continuously updated, evidence-based trust score fused with graph-native reachability analysis (Neo4j) and a multi-agent reasoning layer that produces cited, explainable remediation playbooks. Unlike static allow-lists or reachability-only tools, ADTG unifies live CVE/exploit evidence, maintainer behavior, and exploit-path reachability into a single, continuously recomputed score that drives every downstream recommendation. We describe the system architecture, a simulated multi-tenant demonstration of collaborative trust propagation, an evaluation protocol, and a scoped MVP suitable for a 24–48 hour hackathon build.

Keywords— software supply chain security, SBOM, dependency trust scoring, graph reachability, multi-agent LLM reasoning, explainable AI, threat intelligence, STIX 2.1

I. INTRODUCTION

Modern software is assembled rather than written: a typical production application pulls in hundreds to thousands of transitive open-source dependencies. Attackers have shifted focus accordingly, using dependency confusion, malicious package publication, typosquatting, and compromised maintainer accounts to reach thousands of downstream organizations through a single compromised link. Log4Shell (2021) and the XZ Utils backdoor (2024) remain the canonical examples of this blast radius.

This trend is accelerating rather than historical. Verizon's 2026 Data Breach Investigations Report, drawing on over 22,000 incidents, found that breaches involving a third party now account for 48% of all breaches, up 60% year-over-year, and that vulnerability exploitation has overtaken stolen credentials as the single most common initial-access vector for the first time in the report's 19-year history [Verizon, 2026]. The 2025 edition of the same report found that only 54% of vulnerable edge and third-party components were ever fully remediated, with a median remediation time of 32 days [Verizon, 2025]. Separately, ENISA's Threat Landscape 2025, covering nearly 4,900 incidents across the EU,

describes supply-chain and digital-service compromise as one of the categories with the most cascading, systemic impact [ENISA, 2025].

Despite a mature ecosystem of SBOM generators, CVE scanners, and CTI feeds, organizations still struggle because SBOMs are generated once at build time and go stale within days; threat intelligence is scattered across NVD, OSV, GHSA, and vendor bulletins with no common schema; package "trust" is treated as a static, one-time judgment rather than continuously re-evaluated evidence; and existing tools list vulnerabilities without explaining why a finding matters or what to do about it. The result is a widening gap between detection and action.

A. Verified Research Gap

Cross-referencing the Verizon DBIR (2025/2026), ENISA Threat Landscape 2025, and current SCA/CTI tooling (Snyk, Dependabot, Black Duck, Wiz, MISIP/OpenCTI) surfaces one consistent, specific gap: no widely available platform treats dependency trust as a continuously updated, evidence-based score — fusing live CVE/exploit data, maintainer behavior, and graph-based reachability — and then feeds that score directly into explainable, agentic remediation. Current tools either score trust once (static allow-lists) or reason about reachability without a trust layer at all. This is the gap ThreatMesh AI is built to close, anchored in a single, defensible contribution rather than a broad, harder-to-verify claim of novelty.

II. RELATED WORK

Table I summarizes representative tools across the SCA and threat-intelligence landscape and the specific limitation each leaves unaddressed relative to a continuously updated, graph-aware trust layer.

TABLE I COMPARISON WITH EXISTING SCA / CTI TOOLING

Tool	Strength	Limitation Addressed by ADTG
Snyk	Fast, broad vulnerability detection	Static trust/severity scoring; no live graph reachability
Dependabot	Low-friction automated upgrade PRs	No prioritization by business impact or reachability
Black Duck	Mature SCA and license-risk analysis	Point-in-time scans; no continuously evolving trust signal
Wiz	Strong cloud security posture management	Dependency reasoning secondary

Tool	Strength	Limitation Addressed by ADTG
		to infra posture; not graph-native
MISP / OpenCTI	Solid threat-intel sharing and storage	No correlation of intel against a live dependency graph

III. PROPOSED SYSTEM: THREATMESH AI

ThreatMesh AI is an SBOM-anchored cyber threat intelligence platform built around one core innovation: the Adaptive Dependency Trust Graph (ADTG). The system continuously ingests live SBOMs and CVE/CTI feeds, normalizes them into STIX 2.1, builds a Neo4j knowledge graph of packages, versions, and services, and computes a dynamic trust score for every dependency, which a multi-agent reasoning layer uses to generate explainable, evidence-backed remediation playbooks. The design principle is deliberately narrow: one score, one graph, one explainable recommendation, continuously updated rather than static.

A. Core Innovation: Adaptive Dependency Trust Graph

Instead of a static reputation label assigned once, ADTG evaluates every package's trustworthiness continuously using signals that are each independently available and machine-readable:

- Historical CVE frequency and severity
- Public exploit availability and activity
- Maintainer responsiveness (time-to-patch on prior CVEs)
- Release cadence and repository health
- Package popularity and download/usage footprint
- Reachability of the package from an exposed entry point in the dependency graph

Whenever new evidence arrives — a new CVE, a patch, a maintainer going inactive — the score updates automatically, and every downstream recommendation that depends on it updates as well. This converts trust from a one-time judgment call into a live signal, which is the single idea the system is designed to be remembered for.

B. System Architecture

The platform is organized into six independently demoable stages, summarized in Table II.

TABLE II SYSTEM ARCHITECTURE STAGES

Stage	Function	Key Technology
1. Ingestion	Pulls SBOMs (CycloneDX/SPDX), CVE feeds (NVD, OSV, GHSA), and repo metadata	FastAPI ingestion services
2. Normalization	Converts feeds into a common STIX 2.1 schema for interoperability	STIX 2.1, python-stix2
3. Correlation Graph	Models packages, vulnerabilities, and services as	Neo4j, Cypher

Stage	Function	Key Technology
	nodes/edges; computes reachability	
4. ADTG Scoring	Computes and continuously updates the dynamic trust score per package	Weighted scoring engine over graph + feed data
5. Agentic Reasoning	Threat / Risk / Patch / Compliance agents debate and reach consensus	Agent-orchestrated LLM pipeline
6. Explainable Output	Generates a cited, step-by-step remediation playbook and updates dashboard	LLM-generated playbooks, React dashboard

C. Multi-Agent Reasoning

A council of five specialized agents produces independent assessments that are reconciled into a single consensus recommendation, so the output reflects a debate rather than a single black-box score:

- Threat Agent — identifies and characterizes the active threat.
- Risk Agent — estimates business impact using graph reachability.
- Trust Agent — owns and updates the ADTG score for the affected package.
- Patch Agent — proposes a compatible, verified upgrade path.
- Compliance Agent — maps the finding to relevant security standards.

D. Explainable Output: Worked Example

Consider package xyz-lib, affected by CVE-2026-XXXX, reachable from the payment API, with a public exploit available and a maintainer inactive for over 90 days. ADTG lowers the trust score to 38/100 and the system recommends upgrading to v4.3.1, with the stated reason that the upgrade fixes the critical CVE and is confirmed compatible with the existing dependency tree. Every step in this chain is traceable to a specific graph node or feed source, which is what makes the recommendation auditable rather than a guess.

IV. SIMULATED MULTI-ENVIRONMENT CORRELATION

Real cross-organization data sharing raises data-sensitivity, competitive, and legal questions that cannot be credibly resolved inside a hackathon timeline. ThreatMesh AI instead demonstrates the collaborative value of ADTG in a way that is fully buildable and explicit about what is simulated. The demo runs two to three simulated tenant environments (e.g., a fintech app and a healthcare app) inside the same ThreatMesh instance, each with its own SBOM, but sharing the same underlying ADTG package-trust layer. A CVE or exploit observed against a package in Tenant A immediately lowers that package's trust score for Tenants B and C, and the dashboard visibly shows the score dropping across tenants in real time as the simulated incident propagates. Federated, privacy-preserving sharing across real organizations is presented explicitly as future scope (Section VI), which is a more credible position than claiming a working cross-organization network.

V. MVP SCOPE AND FUTURE WORK

Table III separates the components built and demoed within a 24–48 hour hackathon window from an explicitly labeled roadmap of more ambitious, longer-horizon capabilities.

TABLE III MVP FEATURES VS. FUTURE SCOPE

MVP (Hackathon Build)	Future Scope (Roadmap)
Living SBOM, diffed on every commit	Privacy-preserving, federated intel sharing across real orgs
Live CVE monitoring (NVD/OSV/GHSA)	Cyber digital twin for pre-deployment impact simulation
STIX 2.1 normalization	Predictive attack-path forecasting
Neo4j graph with reachability queries	Closed-loop autonomous learning from remediated incidents
ADTG dynamic trust scoring	
Multi-agent reasoning (Threat/Risk/Patch/Compliance)	
Explainable, cited remediation playbooks	
Simulated multi-tenant trust-propagation dashboard	

VI. EVALUATION METRICS

We propose evaluating ThreatMesh AI along six axes, summarized in Table IV: ranking precision, responsiveness, reachability correctness, false-positive reduction relative to a flat CVE-list baseline, remediation speed, and explainability coverage.

TABLE IV EVALUATION METRICS

Metric	What It Validates
Trust score precision	ADTG ranks genuinely risky packages higher, validated against known-CVE packages
Graph update latency	Time from new CVE/SBOM event to updated trust score
Reachability accuracy	Graph correctly identifies exploitable paths vs. false positives
False-positive reduction	Improvement vs. a baseline flat CVE list
Mean time to remediation (MTTR)	End-to-end responsiveness in the simulated environment
Explainability coverage	Percentage of recommendations with a fully cited evidence chain

VII. DEMONSTRATION WALKTHROUGH

A five-to-seven-minute demo proceeds as follows: (1) a developer adds a new dependency and ThreatMesh diffs the SBOM within seconds; (2) a newly disclosed CVE affecting that dependency is detected from live feeds; (3) the Neo4j graph identifies a reachable attack path from an exposed API; (4) ADTG recalculates and visibly lowers the package's trust score on screen; (5) the multi-agent council evaluates severity, business impact, and

a remediation path, reaching a consensus recommendation live; (6) ThreatMesh generates an explainable remediation playbook citing the exact graph evidence used; and (7) the dashboard shows the same trust-score drop propagating to the two other simulated tenant environments, demonstrating the collaborative value of ADTG.

VIII. DISCUSSION

ThreatMesh AI is deliberately scoped around one clear, defensible innovation — ADTG — rather than a list of loosely connected features, which keeps the contribution easy for reviewers or judges to understand and recall. The motivation is grounded in current, cited data (Verizon DBIR 2025/2026, ENISA Threat Landscape 2025) rather than generic claims about rising threats. The system is trust-aware by design, using dynamic, evidence-based scoring rather than a static allow-list or one-time reputation label, and explainable end-to-end, since every recommendation traces back to specific graph evidence and feed sources. It is also standards-compliant, built on SBOM formats and STIX 2.1 for interoperability with existing enterprise tooling, and honestly scoped: a working MVP plus a clearly separated, ambitious-but-labeled roadmap.

IX. CONCLUSION

By fusing a continuously updated trust graph with explainable, multi-agent remediation, ThreatMesh AI shortens the gap between detecting a supply-chain threat and acting on it correctly — the exact gap the 2025/2026 Verizon DBIR data shows is currently measured in weeks, not minutes. It moves supply-chain defense from static, one-time scanning toward a living system that becomes more accurate every time it observes a new incident. ThreatMesh AI introduces the Adaptive Dependency Trust Graph: a continuously updated, evidence-based trust layer fused with graph-native reachability analysis and multi-agent explainable reasoning, closing the gap between detecting a supply-chain threat and knowing exactly what to do about it.

REFERENCES

- [1] Verizon, "2026 Data Breach Investigations Report," Verizon Business, 2026.
- [2] Verizon, "2025 Data Breach Investigations Report," Verizon Business, 2025.
- [3] ENISA, "ENISA Threat Landscape 2025," European Union Agency for Cybersecurity, Oct. 2025.